

Informe Laboratorio 3

Sección 1

Benjamín Zúñiga Pueller
e-mail: benjamin.zuniga2@mail.udp.cl

Mayo de 2026

Índice

1. Descripción de actividades	2
2. Desarrollo de actividades según criterio de rúbrica	2
2.1. Identifica el algoritmo de hash utilizado al momento de registrarse en el sitio	2
2.2. Identifica el algoritmo de hash utilizado al momento de iniciar sesión	4
2.3. Genera el hash de la contraseña desde la consola del navegador	4
2.4. Intercepta el tráfico login con BurpSuite	5
2.5. Realiza el intento de login	6
2.6. Identifica las políticas de privacidad o seguridad	6
2.7. Demuestra 4 conclusiones sobre la seguridad	7

1. Descripción de actividades

Su objetivo será auditar la implementación de algoritmos hash aplicados a contraseñas en páginas web desde el lado del cliente, así como evaluar la efectividad de estas medidas contra ataques de tipo Pass the Hash (PtH). Para llevar a cabo esta auditoría, deberá registrarse en un sitio web y crear una cuenta, ingresando una contraseña específica para realizar las pruebas.

Al concluir la tarea, es importante que modifique su contraseña por una diferente para garantizar su seguridad.

Dado que la cantidad de sitios chilenos que utilizan hash es limitada, se permite realizar esta tarea en cualquier sitio web a nivel mundial. En este sentido, realice las siguientes actividades:

- Identificación del algoritmo de hash utilizado para las contraseñas al momento del registro en el sitio.
- Identificación del algoritmo de hash utilizado para las contraseñas al momento de iniciar sesión.
- Generación del hash de la contraseña desde la consola del navegador, partiendo de la contraseña en texto plano.
- Interceptación del tráfico de login utilizando BurpSuite desde su equipo.
- Realización de un intento de login, modificando una contraseña incorrecta por el hash obtenido en el punto anterior.
- Descripción de las políticas de privacidad o seguridad relacionadas con las contraseñas, incluyendo un enlace a las mismas.
- Cuatro conclusiones sobre la seguridad o vulnerabilidad de la implementación observada.

2. Desarrollo de actividades según criterio de rúbrica

Para la realización de las actividades de este laboratorio, se necesitó crear una cuenta de Gmail para poder hacer el registro y el inicio de sesión en la siguiente página web de Integle (plataforma científica china).

2.1. Identifica el algoritmo de hash utilizado al momento de registrarse en el sitio

Una vez ya hecho todo lo anteriormente mencionado se procedió a la creación de una cuenta en la plataforma de integle donde se ingreso el gmail y se genero una contraseña (*password1*). Este proceso se puede apreciar en la Figura 1.



The registration form is divided into two tabs: '手机号注册' (Register with mobile number) and '邮箱注册' (Register with email). The '邮箱注册' tab is active. The form includes the following fields and elements:

- 邮箱 (Email):** A text input field containing 'cgrafia56@gmail.com' with a blue checkmark icon on the right.
- 图片验证码 (Image CAPTCHA):** A text input field containing 'M9VG' with a blue checkmark icon on the right. To its right is a CAPTCHA image showing the letters 'M', '9', 'V', and 'G' on a dark background.
- 邮箱验证 (Email Verification):** A text input field containing '5220' and an orange button labeled '获取验证码' (Get verification code).
- 收不到邮箱验证码? (Didn't receive email verification code?):** A link labeled '点击这里' (Click here).
- 登录密码 (Login Password):** A text input field with masked characters '.....'.
- 确认密码 (Confirm Password):** A text input field with masked characters '.....'.
- Terms and Conditions:** A checked checkbox followed by the text '我已阅读并接受《用户服务协议》' (I have read and accept the 'User Service Agreement').
- 注册 (Register):** A large blue button at the bottom.

Figura 1: Formulario de Registro de la pagina de Integle

Una vez terminado todo lo que se nos pedía para poder registrarnos, comenzamos a interceptar los mensajes mediante *Burp Suite* antes de apretar el botón de Submit, donde se nos reveló que el tipo de hash que se utiliza en esta página es MD5. Esto se puede observar claramente encerrado en un rectángulo rojo en la Figura 2.

```

1 POST /register/register HTTP/1.1
2 Host: www.integle.com
3 Cookie: UM_distinctid=19e1c421e29ff5-0bc01039644b298-19525631-1d03d0-19e1c421e2a1e54; CNZDATA1255141213=1820855817-1511344172-null%7C1511344172;
   integle_platform=a80ff9e0jcdabvjet4sv2svn4; _csrf=
   9bcf07ec95dfb8942411dbb4bec165b85dcfb70516271fc0219cd04b169d32a%3A2%3A7B1%3A0%3B%3A5%3A22_csrff%22%3B1%3A1%3B%3A32%3A22R%8E1%1C%23BA%14%B9%8D%5B%8E%0E%8
   %AD%14YF%15D%06D%05%09%05%0DKUx%05%8A%40%AG%22%3B%7D; Hm_lvt_5b0c43485e601e02c0c18a99f767b5c9=1778590490,1778590856,1778704080;
   Hm_lpvt_5b0c43485e601e02c0c18a99f767b5c9=1778704080; HMAccount=A209B02FFDE69919
4 Content-Length: 274
5 Sec-Ch-Ua-Platform: "macOS"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 X-Requested-With: XMLHttpRequest
10 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: application/json, text/javascript, */*; q=0.01
12 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
13 Origin: https://www.integle.com
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://www.integle.com/user/register
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20 Connection: keep-alive
21
22 type=1&email=cgrafia56%40gmail.com&img_code=M9VG&v_code=5220&md5Pwd=7c6a180b36896a0a8c02787eeafb0e4c&token=f5974b29725ffc9702358342bb49b373&expire_time=
   2026-05-14+04%3A38%3A226_csrff=LHD1u1RDqHsM09HQASkJ48BbFLcfYUSFjktKqLDaErG_pynd_m8woEwI40U6eb2R15HZSojPcbcnhSp0ko7A%3D%3D

```

Figura 2: Mensaje de Registro interceptado desde Integle

2.2. Identifica el algoritmo de hash utilizado al momento de iniciar sesión

Ya hecho el registro se procedió a hacer el login con las credenciales ya creadas anteriormente. Donde se pudo ver que la pagina utiliza el algoritmo de hash MD5 tanto en el Registro como en el Login ya que en la Figura 3 podemos apreciar encerrado en un recuadro rojo que en el campo contraseña se encuentra la misma clave que en la sección de login creo mediante el uso de MD5.

```

1 POST /user/login-account HTTP/1.1
2 Host: www.integle.com
3 Cookie: integle_platform=2s16rutnl8f5m2u9erou7kbc66; Hm_lvt_5b0c43485e601e02c0c18a99f767b5c9=1778705581; HMAccount=3d425F9957435B2C; _csrf=
   91f6e7be45acc297ae9eba551d4e7848e0a646af73cc97c4d7b8ac75d996f4e3a%3A2%3A7B1%3A0%3B%3A5%3A22_csrff%22%3B1%3A1%3B%3A32%3A22c%8%A2%4%96%A2%84I%04%0D%E5%E3%A2%
   E0%01%DA%7D%E4%94%AD%0AD-%0C%5B%3A7Ej%25%BB%2A%2F%22%3B%7D; UM_distinctid=19e231d523d1c4d-027cd43c0983d8-19525631-1d03d0-19e231d523e1a16; CNZDATA1255141213=
   1053943366-1511344172-null%7C1511344172; Hm_lpvt_5b0c43485e601e02c0c18a99f767b5c9=1778705586
4 Content-Length: 181
5 Sec-Ch-Ua-Platform: "macOS"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Sec-Ch-Ua-Mobile: ?0
9 X-Requested-With: XMLHttpRequest
10 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: application/json, text/javascript, */*; q=0.01
12 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
13 Origin: https://www.integle.com
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Dest: empty
17 Referer: https://www.integle.com/user/login
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=1, i
20 Connection: keep-alive
21
22 account=cgrafia56%40gmail.com&password=7c6a180b36896a0a8c02787eeafb0e4c&remember=0&_csrf=
   ni8jXquKbVbe4LFW-bSa18n-SYq3y-YRFP58crvLUgn954GaPsjZH9rtVLVBVjsNtBrdJ72Pyx0nxAIYnnB4Jg%3D%3D

```

Figura 3: Mensaje de Login interceptado desde Integle

2.3. Genera el hash de la contraseña desde la consola del navegador

Una vez hecho tanto el proceso de Registro como Login se solicita generar el hash de la contraseña vía consola del navegador a lo que se procedió a ingresar a esta ultima y mediante el comando `hex_md5("password1")` el navegador nos entregaría nuestra clave con el hash

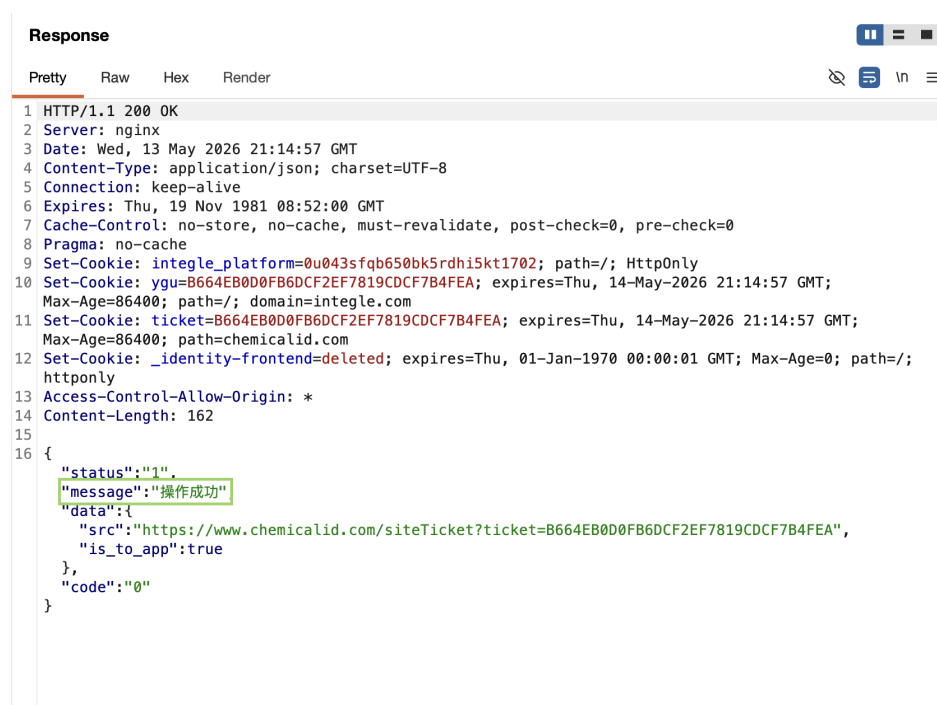
aplicado anteriormente en la plataforma de integle. Esto se puede ver en la Figura 4 donde ingresamos el comando especificado anteriormente y el navegador nos responde con el hash de nuestra clave que viene siendo la misma que se puede ver encerrada en los recuadros rojos de las Figuras 2 y 3.

```
> hex_md5("password1")
< '7c6a180b36896a0a8c02787eeafb0e4c'
```

Figura 4: Generación de hash mediante consola del navegador

2.4. Intercepta el tráfico login con BurpSuite

Hecho ya el Login e interceptados los mensajes se procede a ver el trafico que genera un Login exitoso en el sistema. Se observa en la Figura 5 que primero se ve un status 1 para luego mostrar el mensaje “Operación Exitosa” (encerrado en un recuadro verde) en chino simplificado para finalmente enviar la data.



```
Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Wed, 13 May 2026 21:14:57 GMT
4 Content-Type: application/json; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
8 Pragma: no-cache
9 Set-Cookie: integle_platform=0u043sfqb650bk5rdhi5kt1702; path=/; HttpOnly
10 Set-Cookie: ygu=B664EB0D0FB6DCF2EF7819CDCF7B4FEA; expires=Thu, 14-May-2026 21:14:57 GMT;
Max-Age=86400; path=/; domain=integle.com
11 Set-Cookie: ticket=B664EB0D0FB6DCF2EF7819CDCF7B4FEA; expires=Thu, 14-May-2026 21:14:57 GMT;
Max-Age=86400; path=chemicalid.com
12 Set-Cookie: _identity-frontend=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-Age=0; path=/;
httponly
13 Access-Control-Allow-Origin: *
14 Content-Length: 162
15
16 {
  "status": "1",
  "message": "操作成功",
  "data": {
    "src": "https://www.chemicalid.com/siteTicket?ticket=B664EB0D0FB6DCF2EF7819CDCF7B4FEA",
    "is_to_app": true
  },
  "code": "0"
}
```

Figura 5: Respuesta login correcto

2.5. Realiza el intento de login

Al momento de que se hace un login incorrecto se puede ver en la Figura 6 en un recuadro rojo que el hash no es el mismo además de que la respuesta del sistema lanza un status 0 además de un mensaje indicando que el email o la contraseña no son correctas en chino simplificado (en el recuadro verde).

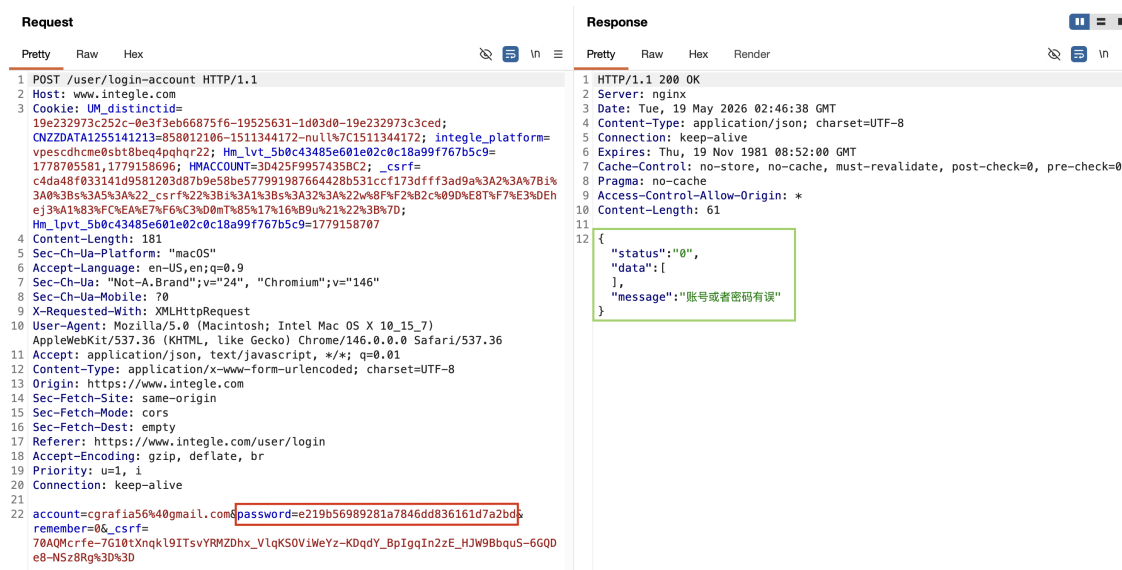


Figura 6: Respuesta login incorrecto

2.6. Identifica las políticas de privacidad o seguridad

Al revisar los Términos de Servicio y la documentación legal de la plataforma científica china **Integle** (orientada a soluciones para laboratorios y cuadernos electrónicos de laboratorio, ELN), se identificaron algunas políticas relacionadas con la seguridad y el uso de cuentas dentro de su *Acuerdo de Servicio al Usuario*.

En relación con la seguridad de la plataforma, se observan los siguientes puntos:

- **Responsabilidad del usuario y restricciones de uso:** La plataforma prohíbe acciones como intentar evadir medidas de seguridad, realizar ingeniería inversa, ejecutar ataques de red o utilizar herramientas automatizadas para acceder a funciones no autorizadas.
- **Protección de credenciales:** El acuerdo establece que cada usuario es responsable de mantener la confidencialidad de su cuenta y contraseña, además de asumir la responsabilidad sobre las acciones realizadas desde su perfil.
- **Acceso al documento oficial:** El acuerdo legal se encuentra disponible públicamente en el siguiente enlace: <https://www.integle.com/static/agreement>.

Sin embargo, a pesar de estas medidas y restricciones definidas en el acuerdo, durante la realización de este laboratorio se identificaron debilidades en el sistema de autenticación que afectan directamente la seguridad de la plataforma.

2.7. Demuestra 4 conclusiones sobre la seguridad

A partir de las actividades previamente realizada al sistema de autenticación y de la prueba de concepto del ataque *Pass the Hash* (PtH) mediante la interceptación de tráfico en la plataforma Integle, se puede concluir que:

1. **El hashing del lado del cliente no entrega seguridad real:** La plataforma calcula el hash de la contraseña usando JavaScript en el navegador antes de enviarlo al servidor. Sin embargo, esto no evita el robo de credenciales, ya que el hash termina funcionando como la contraseña real. Si un atacante obtiene ese valor, puede reutilizarlo para autenticarse sin necesidad de conocer la contraseña original.
2. **La plataforma es vulnerable a ataques de replay o Pass the Hash:** Se comprobó que el sistema no utiliza mecanismos dinámicos de autenticación, como *nonces* o tokens temporales por sesión. Debido a esto, un atacante que capture la petición de inicio de sesión con herramientas como Burp Suite puede reenviarla posteriormente y acceder a la cuenta de manera válida.
3. **Las políticas de contraseñas complejas pierden efectividad:** Aunque la plataforma pueda exigir contraseñas largas o complejas, esta medida deja de ser útil frente a un ataque PtH. El atacante no necesita descifrar la contraseña original, sino solamente reutilizar el hash capturado durante la autenticación.
4. **La vulnerabilidad representa un riesgo importante para la información almacenada:** Integle es una plataforma orientada al almacenamiento de experimentos, fórmulas y datos de investigación. Por lo tanto, una vulnerabilidad de este tipo puede exponer información sensible, propiedad intelectual y datos de investigación y desarrollo, afectando directamente la confidencialidad de los usuarios y organizaciones que utilizan el sistema.